

Analyst: AlJannat A. Uthman
TITLE: Threat Intelligence Brief

OVERVIEW

Two high NGINX vulnerabilities were discovered in a Nessus scan.

The first is a *Byte Memory Overwrite RCE* that leads to a crash (Denial of Service) with CVE number - [CVE-2021-23017](#) and CVSS score - 7.7 High. It only affects nginx 0.6.18 - 1.20.0.

The other one is a HTTP/2 implementation vulnerability that can lead to *Denial of Service*. It has a CVE number - [CVE-2019-9511](#) | 7.5 High.

The screenshot shows the Nessus Vulnerability Management interface. At the top, it says 'GiSOC Vulnerability Management Task / Plugin #150154'. Below this are tabs for 'Hosts' (1), 'Vulnerabilities' (73), 'Remediations' (5), 'Notes' (1), and 'History' (2). The main content area displays a vulnerability titled 'HIGH nginx 0.6.x < 1.20.1 1-Byte Memory Overwrite RCE'. The description states: 'According to its Server response header, the installed version of nginx is 0.6.18 prior to 1.20.1. It is, therefore, affected by a remote code execution vulnerability. A security issue in nginx resolver was identified, which might allow an unauthenticated remote attacker to cause 1-byte memory overwrite by using a specially crafted DNS response, resulting in worker process crash or, potentially, in arbitrary code execution. Note that Nessus has not tested for this issue but has instead relied only on the application's self-reported version number.' The solution is 'Upgrade to nginx 1.20.1 or later.' The plugin details on the right show: Severity: High, ID: 150154, Version: 1.9, Type: combined, Family: Web Servers, Published: June 3, 2021, Modified: September 15, 2022. The risk information at the bottom shows: Risk Factor: Medium, CVSS v3.0 Base Score: 7.7.

The screenshot shows the Nessus Vulnerability Management interface for a different vulnerability. The title is 'HIGH nginx 1.9.5 < 1.16.1 / 1.17.x < 1.17.3 Multiple Vulnerabilities'. The description states: 'According to its Server response header, the installed version of nginx is 1.9.5 prior to 1.16.1 or 1.17.x prior to 1.17.3. It is, therefore, affected by multiple denial of service vulnerabilities : - A denial of service vulnerability exists in the HTTP/2 protocol stack due to improper handling of exceptional conditions. An unauthenticated, remote attacker can exploit this, by manipulating the window size and stream priority of a large data request, to cause a denial of service condition. (CVE-2019-9511)'. The plugin details on the right show: Severity: High, ID: 127907, Version: 1.13, Type: combined, Family: Web Servers, Published: August 16, 2019, Modified: May 2, 2024.

THREAT ACTOR

1. CVE-2021-23017 is not tied to any named adversary groups, at least, according to major Cybersecurity authorities like **CISA** and **NISA**.
2. CVE-2019-9511 has also not been tied to widespread campaigns or ransomware.

ATT&CK Mapping

The following table highlights the associated Tactics (Way), Technique (How) and Procedures (Steps) to both vulnerabilities.

CVE-2021-23017 (NGINX Byte Memory Overwrite RCE)

Tactic (ID)	Technique (ID)	Procedures
Initial Access (TA0001)	Exploit Public-Facing Application (T1190)	Attacker identifies internet-exposed NGINX instance with resolver directive enabled and reachable DNS port (UDP 53).
Execution (TA0002)	N/A	No direct code execution in basic DoS. RCE requires chaining that's rarely observed.
Impact (TA0040)	Network Denial of Service (T1498)	Forges UDP DNS responses from victim's configured resolver IP. Triggers 1-byte heap overwrite. Worker process crash or infinite loop.
Command and Control (TA0011)	N/A	N/A
Discovery (TA0007)	Remote System Discovery (T1018) or Network Service Scanning (T1046)	Scans for open UDP/53 and HTTP(S) ports. Tests for NGINX via banners or error pages.
Defense Evasion (TA0005)	Impair Defenses: Disable or Modify Tools (T1562) (conditional)	Spoofed DNS packets bypass source IP validation if resolver lacks DNSSEC or source checks.

CVE-2019-9511 (NGINX HTTP/2 DOS)

Tactic (ID)	Technique (ID)	Procedures
Initial Access (TA0001)	Exploit Public-Facing Application (T1190)	Targets HTTP/2-enabled web servers (NGINX, Apache, etc.) on TCP 443/80.
Execution (TA0002)	N/A	No code execution. Pure resource exhaustion.

Impact (TA0040)	Network Denial of Service (T1498)	Opens many HTTP/2 streams, sends large DATA frames in 1-byte chunks, manipulates WINDOW_UPDATE and PRIORITY to prevent flow-control release. Exhausts server memory/CPU.
Resource Development (TA0042)	N/A	Uses public PoC tools or custom scripts to automate stream flooding.
Discovery (TA0007)	Network Service Scanning (T1046)	Probes HTTP/2 support via ALPN in TLS handshake or Upgrade h2c header.

INDICATORS OF COMPROMISE (IOC)

Since there are no public campaigns or adversaries attached to the vulnerabilities, there are no known IOCs. However, some information can be derived from exploit behaviour. The following are a few examples.

- Network/Traffic (pcap).
- System / Application logs.
- Memory Dump.
- Unusual process behaviour.

BUSINESS RISKS

1. Service Downtime (DoS) with High likelihood and can cost up to a million for recovery.
2. Brand and damage in customer trust. This has medium likelihood but can cost more than a million dollars in revenue and recovery.
3. Regulatory non-compliance. This has medium likelihood and each incident might cost up to a million dollars in fine.
4. Data breach can occur from RCE chain. The likelihood is between low and medium but can cost up to a hundred million dollars if successful.
5. Cloud cost spikes.

SOC RECOMMENDATIONS

1. Upgrade nginx to 1.20.1 and other new updates.
2. Disable HTTP/2 if not required.
3. Harden systems and improve SOC and Incident response playbooks.